Passwords are not enough

Tim Matthews, Symantec



Tim Matthews

Fifteen or 20 years ago, a simple username and password were all you needed to keep your most private and personal information safe online. Unfortunately, that is no longer the case. There have been dozens of recent headlines with examples of failed passwords, and claims that a new method of security needs to be discovered and used. This is mostly true.

Alarmingly, many organisations today don't seem too worried with the weakening power of passwords. In fact, many businesses are putting increasingly important and private information under the safety of a simple, hackable password. Because of these practices, the already struggling password becomes entirely ineffective when it comes to protecting data.

Technology experts have been warning for years that passwords have lost their effectiveness as a sole method of defence against increasingly evolved hacking methods designed to exploit password vulnerabilities. In fact, password technology has become so cumbersome to users that many employees are seeking ways to get around it, completely undercutting the security their data and information need.

Fortunately, there is already another technology that can back up and supplement passwords – two-factor authentication (2FA). This helps protect data by requiring two methods by which users verify their identity: something they know (username and password) and something they have (a physical authentication token). Together with passwords, this second authentication factor creates a higher level of security for user logins.

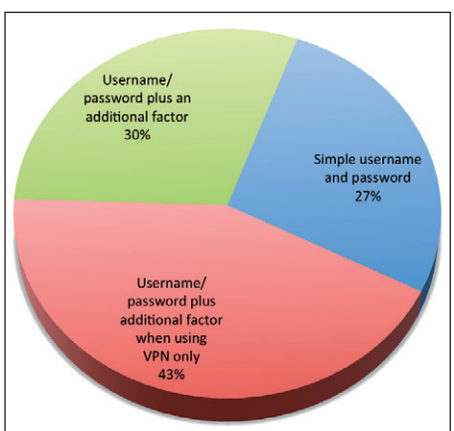


Figure 1: Primary forms of authenticating employees and contractors on corporate networks. Source: Forrester Research/Symantec.

Security risks and administrative burdens

For IT professionals, the security risks of passwords have only become more difficult in recent years with the explosion of cloud and mobile technologies. These have brought about a new set of challenges, including requiring employees and users to remember *more* usernames and passwords.

In December 2010, Forrester Research studied the use of passwords by employees by interviewing 306 IT professionals across several industries.[1] The subsequent report revealed that:

- 87% of users are expected to remember two or more passwords to access corporate resources.
- It is seen as the 'top access problem in the enterprise'.
- 60% of organisations today are using at least two Software as a Service (SaaS) applications and 20% are using six or more.

To meet these challenges, many organisations have implemented policies among their employees to improve password security. However, many users cripple these security systems by reusing passwords and choosing password combinations that are easy to figure out or hack. In fact, some go so far as to continue using the default password if a program or website lets them. While it could take years for hackers to break a strong password, it would take them only hours or minutes to break a weak one.

This problem isn't associated only with employees. The Forrester study found that two-thirds of companies (67%) do not require strong or two-factor authentication from partners to access corporate networks. Even if employees hold firm to company password policies, it only takes one partner using weak password practices to leave the system vulnerable. Due mostly to the weakness of passwords used by those with access to company networks, the Forrester study found that more than half of the businesses surveyed (54%) had experienced a data breach in the previous year. This figure continues to rise as more and more companies implement cloud and mobile technologies.

Defending with two-factor authentication

As data breach and failed password stories continue to crowd the technology sections of newspapers and magazines, many organisations are looking for business-friendly ways to keep their information safe. Fortunately, they don't have to look too far. Two-factor

authentication is not only available as a high-quality and proven method of security, it's also becoming easier and easier to implement.

For convenience, since mobile devices have become more and more prevalent in the workplace, some organisations are taking advantage of apps that allow these devices to act as an authentication token. Unlike traditional security tokens, which employees and partners may lose or forget, most people carry their cellphones with them constantly, whether at home, at work or on the go. This allows organisations to secure data with two-factor authentication with little-to-no upfront costs.

Choosing strong authentication providers wisely

One word of caution: be sure to select a two-factor authentication provider wisely, remembering that not all strong authentication providers are created equal. A recent BBC news article showed evidence of that.[2]

According to the article, hackers were recently able to get past banks' two-factor authentication by using Man-in-the-Browser (MitB) attacks. Using cleverly hidden malware on people's computers, these hackers were able to successfully get between users' computers and the banking websites, moving money around and controlling what users viewed on their screens.

For some, this article brought renewed worry about the abilities of online security companies and programs. Fortunately, with proper research and judgement, businesses can find software and services that keep this type of

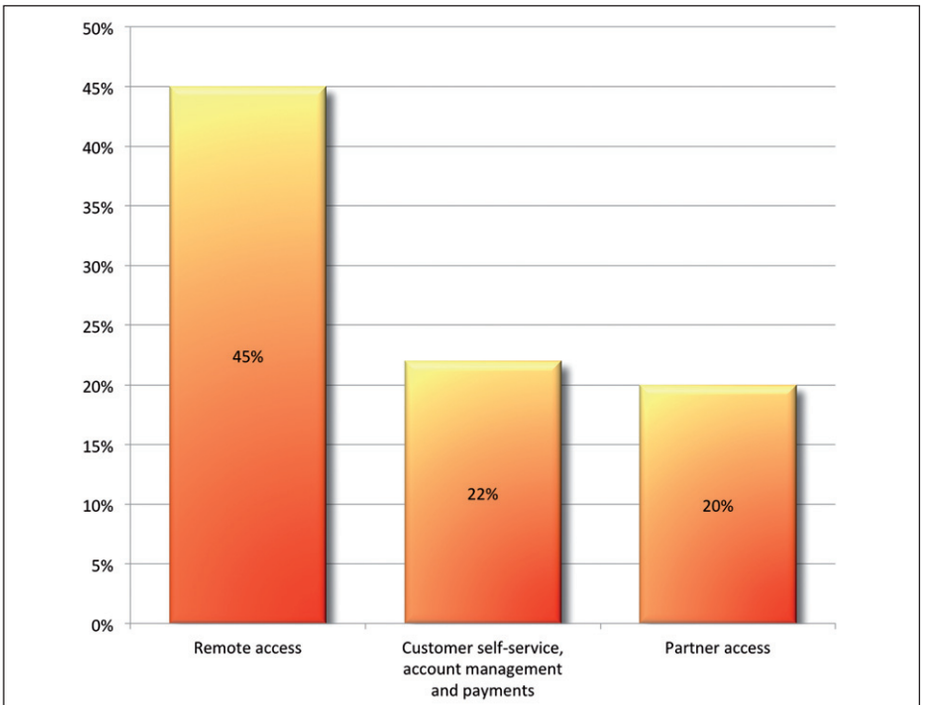


Figure 2: Types of uses for which strong authentication solutions are employed for access to internal networks and applications. Source: Forrester Research/Symantec.

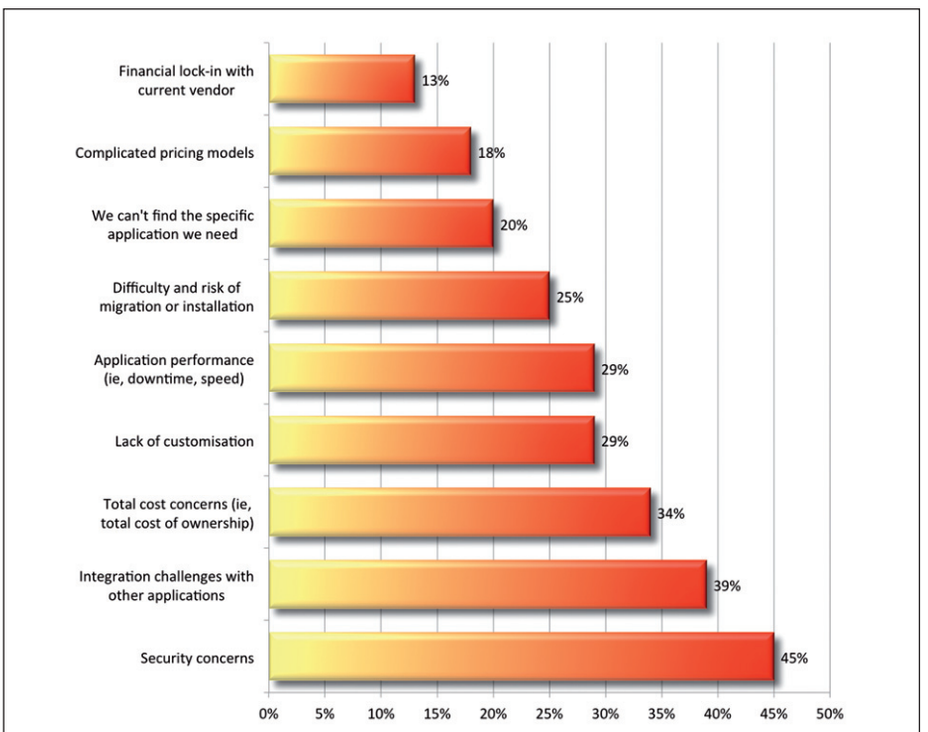


Figure 3: Security ranks top among the reasons for not using Software as a Service (SaaS). Source: Forrester Research/Symantec.

situation from happening to them. There are many choices of software that keep what a person types in for a password and two-factor authentication code hidden from the rest of their system. Even if a person's computer is infected with the malware, their information will stay safe.

Moving forward with confidence

Thanks to recent advances with two-factor authentication, it is becoming increasingly easy for enterprises to follow the Forrester study's recommendations to implement strong authentication throughout their organisations. In an effort to help promote these recommendations, the US Federal Government in March 2011 launched a new programme: the National Strategy for Trusted Identities in Cyberspace (NSTIC).

The NSTIC is a large-scale partnership effort by the US Government and private partners to develop a secure, standards-based online 'identity ecosystem'. Their primary goals are to improve online security and privacy through improved and expanded strong authentication. Jeremy Grant, senior executive adviser at the National Program Office for NSTIC, said in August 2011 that: "We're trying to get rid of passwords. It's time for something better."

In the meantime, businesses can and should be searching out effective, secure two-factor authentication solutions for their business and users. Doing so will help keep their data and information secure, allowing them to focus on those things that will help them be successful in their industry.

About the author

Tim Matthews is senior director of product marketing for Symantec's information protection team. He is responsible for setting product positioning and marketing strategy for data loss prevention, authentication and encryption solutions protecting hard disks, removable media, email, shared files and other critical data. Matthews came to Symantec through the acquisition of PGP Corporation and prior to that worked in product marketing and management at RSA. He has a 20-year career spanning product management, product marketing and systems engineering.

References

1. 'Enhancing Authentication to Secure the Open Enterprise'. Forrester Research/Symantec, Dec 2010. Accessed May 2012. https://www4.symantec.com/mktginfo/whitepaper/user_authentication/whitepaper-forrester-open-enterprise.pdf.
2. Kelly, Spencer. 'Hackers outwit online banking identity security systems'. BBC News, 10 Feb 2012. Accessed May 2012. www.bbc.co.uk/news/technology-16812064.

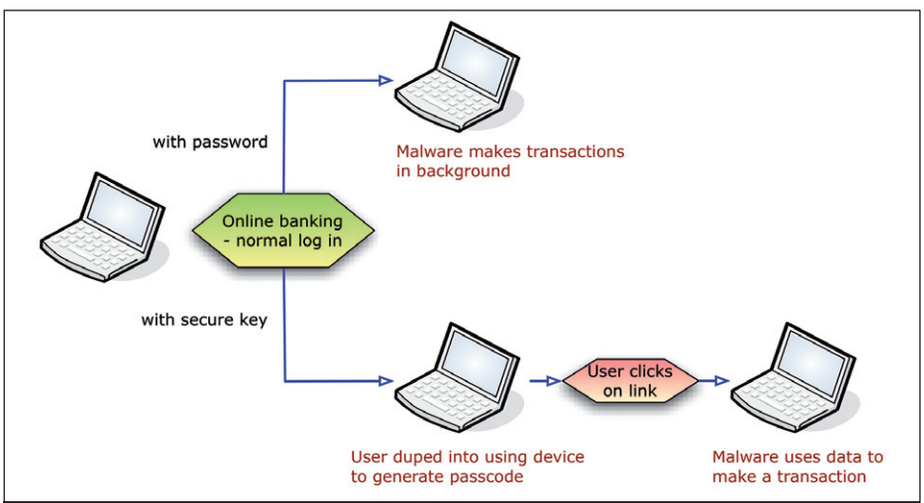


Figure 4: A 'man in the browser' attack on an infected PC can bypass apparently strong authentication methods.

Calendar

7–8 June 2012
1st National Conference on Cyber Security NCCS-2012
Maharashtra, India
www.diat.ac.in/nccs2012/main.html

13 June 2012
5th International Conference on Trust and Trustworthy Computing
Vienna, Austria
www.trust.sba-research.org/index.html

16–22 June 2012
24th Annual First Conference
Malta
http://conference.first.org/program/

19 June 2012
CISO Intelligence Forum: Energy
London, UK
www.ciso-intelligence.com

21 June 2012
SANS Forensics and Incident Response Summit 2012
Austin, Texas, US
www.sans.org/infro/87834

21–26 July 2012
Black Hat USA 2012
Las Vegas, US
www.blackhat.com

26–29 July 2012
DEFCON 20
Las Vegas, US
www.defcon.org/html/defcon-20/dc-20-cfp.html

30 August–2 September 2012
44Con
London, UK
www.44con.com/

26–27 September 2012
Brucon
Ghent, Belgium
brucon.org